

Using Nmap Like a Red Team Operator

What are we doing?

- Learning how to use nmap to scan a target and maintain Operational Security or OPSEC

Why are we doing this?

- Red teams perform threat emulation.
- Their goal is to remain UNDETECTED by blue team
- Standard Nmap scans can reveal the red team's activity
- We want nothing to point back to red team

How are we going to do this?

- Only scan when necessary
 - Shodan
 - <https://shodan.io>
 - Censys
- Slow/Control Rate of scan traffic
 - Scan Timing
 - Slow and steady
 - `-T1 -T2 -T3`
 - `-T0` slows scan to 1 packet every 5 min
 - 8 hrs per 100 ports!
 - `--scan-delay 10s`

- Reduce traffic noise
 - Disable DNS resolution (`-n`)
 - Disable Host Discovery (`-Pn`)
 - Only Essential Ports (`-p 22,80,443,445,3389`)
 - Maybe even 1-at-a-time
 - Only scan target IP not domain name
 - `nslookup scanme.nmap.org`
 - get target IP
- Camouflage/Obfuscate Traffic (*blend in, go unnoticed, disguise as someone else*)
 - Data Length (`--data-length 24`)
 - By default, `nmap` sends empty or fixed-size packets.
 - This switch appends random garbage bytes (in this case, 24 bytes) to the payload of every packet.
 - This changes the packet size, successfully breaking simple packet-length signatures.
 - Set TTL (`--ttl 64|128`)
 - Blend scan traffic with what's expected in target network
 - Linux Default TTL = 64
 - Windows Default TTL = 128
 - Set User Agent When Service Scanning
 - `-sV --script-args http.useragent=<real_user_agent>`
 - <https://useragents.io/>
 - proxies (`proxychains`)
 - SSH/SOCKS redirectors
 - Proxychains

- Tor
 - Likely blocked
 - Exit nodes are well known
- residential proxy networks
 - <https://www.webshare.io/>
 - <https://brightdata.com/proxy-types/residential-proxies>
- Domain Fronting
 - VPS like EC2 will most likely get blocked
 - CDNs like CloudFront help with that
 - High-reputation domains
 - API-abuse
 - "Tunnel" traffic through APIs
- DEMO
 - Scan a target using Proxychains through an SSH/SOCKS redirector and a "residential proxy"
 - Gather necessary info
 - SSH creds/IP
 - Res Proxy creds/IP
 - Modify the `/etc/proxychains4.conf` file
 - `sudo nano /etc/proxychains4.conf`
 - Comment out `proxy_dns`
 - Comment out `socks4 127.0.0.1 9050`
 - Add `socks5 127.0.0.1 1080`
 - Add `http <res_proxy_IP> <port> <username> <password>`
 - `http 30.30.30.134 3128 operator1 ProxyPassword1`
 - Save & Exit

- Start Dynamic SOCKS Proxy connection to SSH Redirector
 - `ssh -N -D 127.0.0.1:1080 root@<ssh_redir_IP>`
- Run Nmap Scan w/Proxychains
 - `sudo proxychains nmap -sT -n -Pn -p 445 <target_IP>`
- Proof of Concept
 - Run `Wireshark` on target
 - Rerun Nmap Scan w/Proxychains
 - Stop `Wireshark`
 - Check `Wireshark` logs for nmap scan
 - Connect scan should come from the Residential Proxy IP
- Challenges/Obstacles
 - Web App Firewalls
 - Workarounds
 - Find real IP of target
 - Get server to send email (forgot login, contact us, web forms, etc)
 - Old DNS info (DNSDumpster)
 - SSL certs may have it
 - Custom JA3 Spoofing Tool
 - Probing ports 1-at-a-time
 - Slow and steady wins the race
 - Bypass rate detection, looks more human